

Requiring Signed GitHub Commits for Repositories

Maggie Ring



GitHub and open-source software

- GitHub is a platform for collaborative software development
 - Stores code, tracks changes, manages access
- Many projects on GitHub are open-source
 - Anyone can view, use, and contribute
 - Around 96% of code bases incorporate open-source software ⁽¹⁾
 - Can be dangerous due to its open nature



Figure 1: GitHub collaborative development



Commits and how they can be faked

- A commit is an update to a project
- Unsigned commits can't verify who really made a change
 - They can be faked to look like they come from a trusted user.

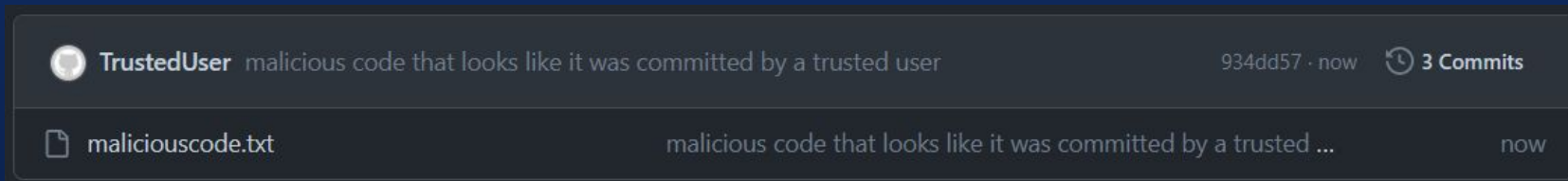


Figure 2: Example of how commits can be falsified to look like they are coming from another account





Signing commits

- The solution to this is signing commits
- This verifies two things:
 - The name on the commit is really the account that committed the code
 - The code has not been tampered with
- Asymmetric encryption creates a public and private key
 - Private key is stored on a users personal device
 - Public key is uploaded to GitHub
- Signed commits are identified by a green check mark and say “verified”





Downsides

- Can be time consuming to get set up
- Potential privacy concerns





Real life attacks

- Open source software attacks and supply chain attacks are more common than ever
 - Millions of forked repos with fake commits impersonating legitimate projects ⁽²⁾
 - Commits faked to look like original developer
 - Fake Dependabot commits ⁽³⁾
 - Signing commits is the best defence





Conclusion

- The security benefit of signing commits outweighs the downsides
- Requiring signed commits significantly mitigates the risk of code injection





Recommendations

- Owners and maintainers of repositories should implement mandatory signed commits.
- Training should be provided to developers
 - Cryptographic key management and best practices

☐ **Require contributors to sign off on web-based commits**

Enabling this setting will require contributors to sign off on commits made through GitHub's web interface. Signing off is a way for contributors to affirm that their commit complies with the repository's terms, commonly the [Developer Certificate of Origin \(DCO\)](#). [Learn more about signing off on commits.](#)

Figure 3: Requiring contributors to sign commits





References

- 1: Ackermann, R. (2023, November 7). The future of open source is still very much in Flux. MIT Technology Review.
- 2: Kadouri, J. H. (2022, August 3). *Large scale campaign created fake github projects clones with fake commit added malware*. Medium.
<https://medium.com/checkmarx-security/large-scale-campaign-created-fake-github-projects-clones-with-fake-commit-added-malware-d6529db5e953>
- 3: Arghire, B. (2023, September 27). *Stolen github credentials used to push fake Dependabot commits*. SecurityWeek.
<https://www.securityweek.com/stolen-github-credentials-used-to-push-fake-dependabot-commits/>
- Figure 1: git-vs-github. (n.d.-a). https://www.kindpng.com/imgv/iwRiwi_git-vs-github-hd-png-download/
- Segala, A. (2020, May 17). *How (and why) to sign Git commits*. With Blue Ink.
<https://withblue.ink/2020/05/17/how-and-why-to-sign-git-commits.html>
- Dubniczky, R. (2022, July 16). *Why and how you should sign all your git commits*. Medium.
<https://betterprogramming.pub/why-and-how-you-should-sign-all-your-git-commits-94435516edae?gi=2fb350be50af>
- Abgaryan, H. (2024, April 15). *Why you should sign your commits on github*. Medium.
<https://medium.com/@harutyunabgaryann/why-you-should-sign-your-commits-on-github-2ebd2d4102ee>
- Lorenc, D. (2021, July 4). *Should you sign git commits?*. Medium.
<https://dlorenc.medium.com/should-you-sign-git-commits-f068b07e1b1f>
- NVD. (n.d.-a). <https://nvd.nist.gov/vuln/detail/CVE-2024-3094>
- *Microsoft FAQ and guidance for XZ Utils Backdoor*. TECHCOMMUNITY.MICROSOFT.COM. (2024, April 7).
<https://techcommunity.microsoft.com/t5/microsoft-defender-vulnerability/microsoft-faq-and-guidance-for-xz-utils-backdoor/ba-p/4101961>





Thank you!

Sign your commits

